

4. **BEST PRACTICES**

Good practices in terms of cybersecurity policies, procedures, and controls.



IMPLEMENTATION

IMPLEMENTATION BEST PRACTICES

When implementing the PCI DSS (or any other cybersecurity compliance framework), there is a set of best practices that always help. These include:

- Having management buy-in
 - Without this, it's hard to obtain budget or resources;
- Minimizing the scope
 - The less is in scope of PCI DSS, the less strict controls;
- Minimizing data collected
 - The less data that we keep, the less we have to protect;
- Extensive logging
 - The more that we log, the more that we will know;
- Proper vetting of everyone
 - People, service providers, partners, and many others;

IMPLEMENTATION

BEST PRACTICES

First, obtaining management buy-in is crucial:

- A lot of security controls and techniques (especially the best ones) cost. Not just in terms of licenses or material, but trained people, too;
- If those at the top don't understand the importance of good security, of protecting data, of preventing incidents... then it's hard to get anything done well, really;

Then, minimizing the scope of the CDE also matters:

- Sometimes, it's a trade-off. You have higher costs (e.g., separating a system that does CDE + other things into two different ones), but you save due to less required compliance;
- In many cases, just outsourcing whole activities works;





IMPLEMENTATION

IMPLEMENTATION BEST PRACTICES

Then, minimizing the data collected also helps:

- Not just in PCI DSS, but in general. Remember that, unless well protected, data are liabilities, not assets!
- The less data, the less work needed to protect them;
- The only exception to this are logs (log everything);
- It can be an ego issue. You don't need card data (in fact, you can't even use them for anything). Let them go;

Then (ironically), save as much log data as possible:

- The goal is to prevent future attacks. You want to know everything about possible entry points and vectors;
- All information that helps you piece together attacks helps;
- The goal is not to log blindly. It's to log specific, exact pieces of evidence that will help later;

IMPLEMENTATION

BEST PRACTICES

Finally, properly vetting everyone and everything:

- Employees, vendors, software, physical systems, etc;
- This seems a lot sexier than it is... It's about interviewing people, doing checks, reading manuals and more manuals, and so on;
- It's about checking that everything makes sense, and “nothing is off”;
- It's one of those things that is tedious to do and takes a long time... but your future self will thank you;



IMPLEMENTATION

BEST PRACTICES

EXAMPLES

/01 FORGET THE EGO

A lot of organizations have in-house portals, card data repositories, and more when outsourcing would work. Unless you need to do something... just outsource it.

/02 INVEST IN THE SAQ

Performing the SAQ is an important moment in an organization and shouldn't be discounted. It can cost you time (unneeded questions) or compliance (fail).

/03 SAY “NO” BY DEFAULT

Another principle that could merit its place here is to say “no” by default. Deny people, deny traffic, deny exceptions to requests, and everything else you can.

IMPLEMENTATION

BEST PRACTICES

KEY TAKEAWAYS

/01 HAVE BUY-IN

Having support from senior management is crucial. Only they can unlock budget, resources, and internal openness to new controls, policies and programs.

/02 MINIMIZE THE SCOPE

Minimizing the scope of the CDE minimizes all the strict protections needed. What do you *really* need to do with card data? It may be less than you think.

/03 MINIMIZE DATA

Minimizing the data that you collect minimizes the protections needed for them (this also applies outside the PCI DSS). If you don't need them, don't store them.

/04 MAXIMIZE LOG DATA

Log data are the exception. Log everything that you can that may help reconstruct future attacks and prevent future ones. Log specific, exact information.

/03 VET EVERYTHING/EVERYONE

Finally, ensure that you properly validate every person, every system, every license, and everything else that comes into the organization. It's tedious, but crucial.